

API Security Risk Analysis Report

Prepared By : Deney Dasari

API Tested: JSONPlaceholder Test API

URL: <https://jsonplaceholder.typicode.com>

Testing Date: 30 May 2026

Tools Used:

- Postman
- Browser Developer Tools
- GitHub

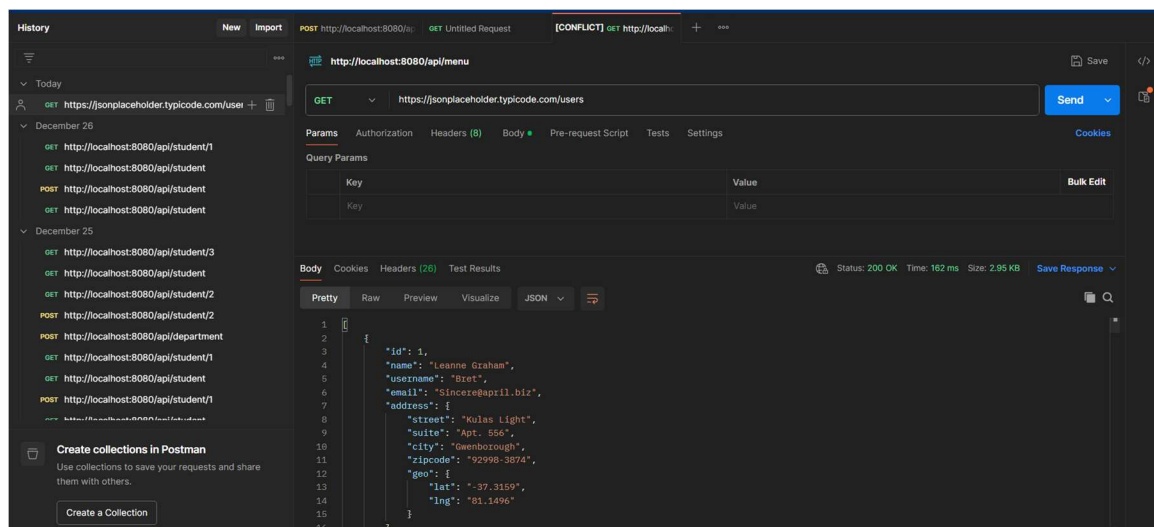
Methodology:

1. Reviewed API documentation
2. Tested endpoints using Postman
3. Inspected responses and headers
4. Identified security risks
5. Assigned risk severity
6. Suggested remediation

Finding 1: Missing Authentication

Severity: Medium

Evidence: The /users endpoint returned data without requiring login, API key, or token.



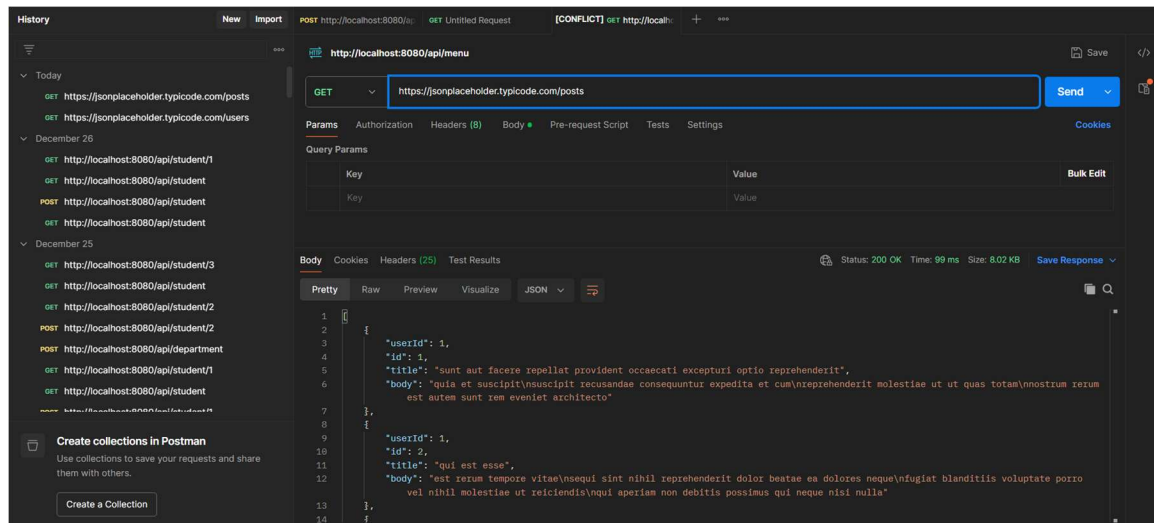
Business Impact: Unauthorized users can access user information.

Recommendation: Implement API Key, JWT, or OAuth authentication.

Finding 2: Excessive Data Exposure

Severity: Medium

Evidence: User endpoint exposes name, email, phone, address, and website.



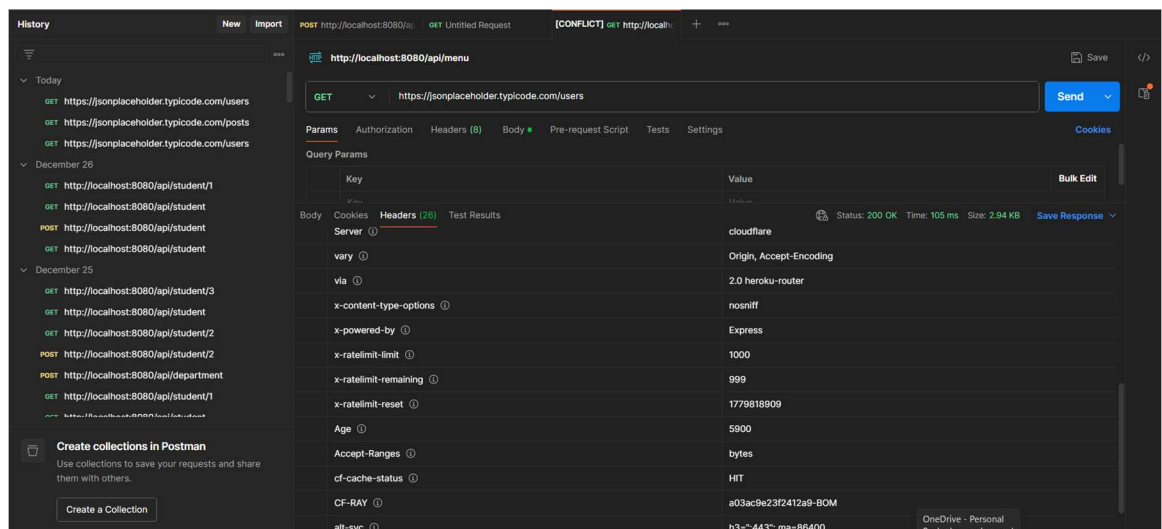
Business Impact: Information may be useful for phishing or reconnaissance.

Recommendation: Return only necessary fields.

Finding 3: Rate Limiting Implemented

Severity: Informational

Evidence: Response headers contain `x-ratelimit-limit`, `x-ratelimit-remaining`, and `x-ratelimit-reset`.



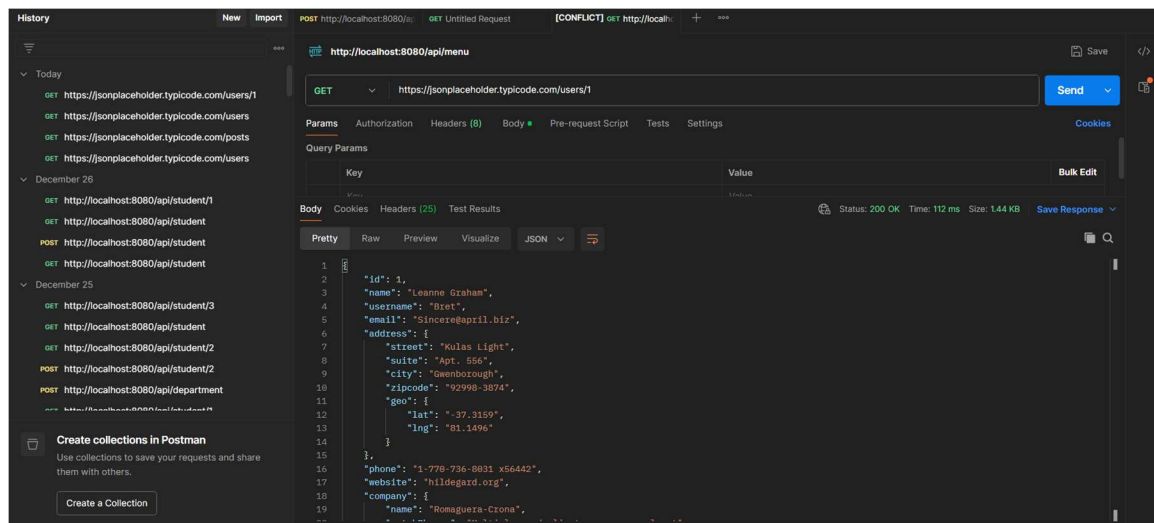
Business Impact: Helps protect the API from excessive requests and abuse.

Recommendation: Continue monitoring and tuning rate limits based on usage patterns.

Finding 4: Predictable Resource IDs

Severity: Low

Evidence: Sequential IDs are used for resources.



Business Impact: Easier enumeration of records.

Recommendation: Enforce authorization checks and consider non-sequential identifiers.

Conclusion:

The API is intended for testing purposes. In a production environment, stronger authentication, data minimization, rate limiting, and security controls should be implemented.